

Incident Response Operating Model

Severity, ownership, escalation, evidence, communications, and closure

Severity	Criteria	Examples	Response
SEV-1 Critical	Material outage, widespread compromise, ransomware, confirmed sensitive-data exposure	Major breach, widespread ransomware, critical admin takeover	Immediate incident command; executive/legal/privacy as applicable; continuous updates
SEV-2 High	Confirmed malicious activity with bounded but important impact	Privileged endpoint compromise, serious DDoS, successful phishing compromise	Rapid containment; IR lead; frequent updates; same-day action plan
SEV-3 Medium	Suspicious or malicious activity with limited scope	Single compromised endpoint, failure-only brute force, blocked malicious email	Analyst investigation; targeted containment; tracked remediation
SEV-4 Low	Informational, benign, or routine	Known scanner, blocked probe, low-risk policy event	Document disposition; tune or route to normal queue

RACI / Ownership

Activity	SOC Tier 1	IR Lead	IT / Cloud	Legal / Privacy	Business Owner
Alert triage	R	A/C	C		
High-severity incident	C	A/R	R	C	C
Containment	R within runbook	A	R	C if data/legal	C
Evidence preservation	R	A/R	C	C	
Customer / regulator communication		C		A/R	C
Recovery	C	A	R	C	R
Post-incident review	C	A/R	R	C	R

Incident Lifecycle

- Preparation: contacts, tooling, severity, playbooks, evidence procedures, backup validation.
- Detection & analysis: validate alert, scope assets/users/data, establish timeline, classify severity.
- Containment: reduce immediate risk while preserving required evidence.
- Eradication: remove persistence, compromised credentials, malicious tooling, and exploited weaknesses.
- Recovery: restore trusted systems, validate functionality, monitor for recurrence.
- Post-incident: root cause, lessons learned, corrective actions, owners, due dates, and validation.